

Mal

Global Accounts — United States · Money Services Business (Zenius Bank rails)

Customer Risk Assessment Methodology

Customer Risk Rating / Customer Risk Assessment Model (CRA/CRAM) — US Perimeter

Document classification: Internal — Board & Senior Management

Document reference: Mal-CRAM-US-01 · Authoritative model version CRAM-US-2026-07-FREEZE-03

Document owner: U.S. AML/BSA Compliance Officer (board-confirmed CO) — Model Owner for the US perimeter, reporting directly and independently to the Board; Group model-governance support (MLRO / Model Risk Committee) operates under the CO's second-line authority

Version: 1.0 (Board Resolution alignment refresh — reconciles governance, corridor and SAR-filing sections to the board-adopted AML/BSA Compliance Program dated 31 March 2026; no model change; FREEZE-03 unchanged)

Date: July 2026

This document has been prepared for a specific purpose and should not be used for any other purpose or by any other party. It is not to be copied or made available to any person other than the recipients without the express written consent of an authorized person. No part may be modified, distributed or stored without prior written permission from the Company. It may contain confidential or legally privileged information; unauthorised disclosure, copying or distribution is strictly prohibited.

Contents

Contents	2
1. Introduction, Objective and Scope	3
2. Governance & Oversight	4
3. Authoritative Scoring Framework	6
4. Customer Segments and Relationship Hierarchy	7
5. Factor Weights by Segment and Lifecycle Stage	7
6. Parameter Libraries and Scoring Rules	7
7. Geography and Country Risk Methodology	10
8. Product and Service Risk Methodology	13
9. Digital Onboarding and Channel Assurance	13
10. Expected Activity, Behaviour and Typology Anchoring	14
11. Screening, Sanctions, PEP and Adverse Intelligence	15
12. Overrides, Risk Floors and Prohibitions	16
13. Due Diligence, Approval, Monitoring and Review Outcomes	16
14. Data Model and Data Quality	17
15. Calculation Sequence, Workflow and SLAs	18
16. Record Keeping, Audit Trail and Explainability	19
17. Model Governance, Validation and Change Control	19
18. MI, KRIs and Ongoing Monitoring	19
19. Final Methodology Control Statement	19
20. Appendices	20

1. Introduction, Objective and Scope

This document establishes the Customer Risk Assessment Methodology (“CRA/CRAM”) of Mal Money Inc. (“Mal”, trade name Mal Money) for the United States regulatory perimeter of the Global Accounts (“GA”) program operated on Zenus Bank rails. It defines the policy, data, scoring, override, workflow and governance rules used to identify, assess, score, approve, monitor, reassess and evidence customer financial-crime risk across the individual and SME populations.

It is subordinate to the AML/CFT (BSA) Compliance Policy (Anti-Money Laundering, Counter-Terrorist Financing and Counter-Proliferation Financing Policy) and the Customer Risk Rating Policy (Customer Risk Rating Policy), read with the CIP, CDD and Beneficial Ownership Policies. This Methodology operates under, and is governed by, the board-adopted AML/BSA Compliance Program dated 31 March 2026 (the “Program”), the Board-approved instrument of record; until the Customer Risk Rating Policy (Customer Risk Rating Policy) receives its own Board approval, the Program and this Methodology govern, and on any conflict the Program prevails. Where any provision conflicts with the parent Policy, the Policy prevails; where US law, FinCEN or OFAC obligations, formal supervisory direction, or Zenus Bank contractual requirements impose a stricter standard, the stricter standard governs and prevails across every corridor.

The framework calculates an inherent customer risk score on a 1.0000–3.0000 scale, assigns one of three mathematical ratings (Low / Medium / High), applies hard stops and non-dilutable floors, and routes the customer to the required CDD, EDD, approval, monitoring and review outcome. Mathematical scoring is deliberately separated from mandatory overrides so that sanctions, PEP, SAR, UBO-verification failure, prohibited products/countries, synthetic identity and failed digital identity cannot be diluted by weighted averaging.

1.1 Objective

Enable consistent, explainable and auditable decisions on acceptance, CDD/EDD, approval authority, monitoring intensity, review frequency, restrictions, rejection, freezing, exit and regulatory escalation. Each in-scope customer and material related party receives a reproducible record linked to a `model_version_id`; the raw score is computed to ≥ 4 decimals with thresholds on the unrounded score; mandatory factors and critical fields are populated, blocked or conservatively treated before approval (no default-to-Low); hard stops and floors apply independently of the weighted score; reason codes and evidence are generated for every non-Low factor, override, data-quality exception and decision; event-driven reassessment fires on material change; and every rating is reconstructable to the 10-business-day examiner-production standard.

1.2 Scope

Applies to FLOD, Compliance (SLOD) and control/support functions across onboarding, refresh, event-driven review, remediation, restriction, exit review and portfolio batch re-score. Covers natural persons of every employment type; legal persons (SMEs) and their beneficial owners/control persons; and FI/regulated partners only where they qualify as permitted end-users (Section 6.4). Channels are non-face-to-face by design. Products: USD accounts and VRNs, inbound/outbound USD (ACH, SWIFT), card spend (Rain/Visa), and cross-border payout corridors (SwiftX stablecoin-settled; Thunes bank payout; SWIFT fallback). FATCA/CRS classification is outside scope, save that a US-person/TIN data point may feed CIP completeness. This Methodology produces the financial-crime risk rating only.

2. Governance & Oversight

2.1 Roles & responsibilities

Role	Responsibility
Board of Directors	Adopts the AML/BSA Compliance Program dated 31 March 2026 (the “Program”) under which this Methodology operates, and approves the Customer Risk Rating Policy fronting it. Receives the quarterly Board compliance dashboard (Program Annex 12) and the annual Program Effectiveness Report; commissions the independent AML audit; approves go-live of High and Very High Risk corridors and is notified of Medium-High corridors within 30 days. Program approval, audit commissioning and High/Very High corridor authorization are non-delegable.
Model Risk Committee	Internal model-governance body: approves the model freeze, validation calendar and material model changes and tracks the launch+90 live-data re-score to closure. It supports, and does not displace, the Board’s reserved matters or the U.S. AML/BSA Compliance Officer’s second-line authority.
Model Owner — Group MLRO (Hub)	Owns this Methodology, its configuration, the typology corpus (MAL-TA-01) and the Decision Provenance Log; approves parameter/threshold changes via change control. Operates under the U.S. AML/BSA Compliance Officer’s second-line authority. Corridor risk appetite is set by the Board (which approves High/Very High corridor go-live) with U.S. CO sign-off, not owned unilaterally by this role.
US BSA Officer (Spoke)	This is the Company’s board-confirmed U.S. AML/BSA Compliance Officer (the “CO”). Owns US-perimeter execution: CIP/CDD/EDD outcomes, SAR/OFAC consequences of ratings, High-band admissions sign-off; personally accountable for FinCEN filings arising from rated relationships. The CO reports directly and independently to the Board with no management intermediary filtering communications; CO authority extends to all corridors and all compliance functions; CO compensation is not tied to revenue, profit or customer-acquisition metrics; CO removal requires a formal Board resolution. Local compliance coordinators (e.g., Head of Compliance, Pakistan) support first-line consistency and do not substitute for the CO’s second-line independence. The CO is excluded from the independent testing function (Section 17).
Second Line — Compliance (SLOD)	Independent oversight and challenge; QA of scoring quality; adjudication of screening and EDD outcomes feeding the score.
First Line — Product/Ops/CS	Ensures completeness/accuracy of onboarding data and the expected-activity profile; escalates red flags; executes controls in the flow.
Data Governance	Owns source-to-target mapping, field-level data quality for scoring-critical fields, and lineage/reproducibility.
Vendor Governance / Fraud	Vendor due diligence and independent validation of Oscilar decisioning, Shufti (individual KYC) and SumSub (KYB / KYB transaction monitoring).

2.2 Core design principles

- **Risk-based and evidence-led** — outcomes are driven by verifiable data and controlled libraries; every non-Low factor carries a reason code and evidence reference.
- **Non-dilution** — hard stops and mandatory floors (sanctions, prohibited types/countries, verification failure, confirmed suspicion) sit above the weighted score and can never be averaged away.
- **Three tiers only** — the model produces exactly three risk tiers — Low, Medium, High. There is no Critical or Moderate-High tier. Prohibited / Blocked / Reject / Exit is an override outcome (an action), not a rating tier.
- **No default-to-Low** — missing, unmapped, inconsistent or stale data is treated conservatively (Medium/High or blocked).
- **Residency-primary, non-discriminatory geography** — country risk is driven primarily by country of residence and the geography of funds, not by nationality or country of birth. Nationality and birth are screening/EDD inputs, not weighted scoring inputs (Sections 7 and 11).

- **Inherent risk first; point-in-time reproducibility** — mitigating controls affect treatment, not suppression of inherent risk below its floor; every assessment is reproducible with the exact inputs, model and library versions in force.

2.3 Access governance — authorized users

Only enrolled authorized users may engage client services or compliance on a master account. One Authorized-User Access Request form is submitted per master account (five master accounts in total), each including the CEO email and signature. Requests from non-enrolled parties are not actioned; the access register is maintained by Compliance and evidenced in the audit trail (Section 16).

2.4 Regulatory alignment and model interpretation rules

This Methodology is aligned with the United States AML/CFT legal framework and supervisory expectations for a money-services business operating on Zenus Bank rails, and interprets them as follows:

Regulatory expectation	Methodology response
Risk-based CDD and EDD (BSA / FinCEN AML-program rule for MSBs, 31 CFR 1022.210; FinCEN CDD Rule; FFIEC CDD/EDD)	The customer risk rating is the risk-based engine that sets CDD depth, EDD triggers, approval authority, limits, monitoring intensity and review frequency.
Customer identification (USA PATRIOT Act §326; 31 CFR 1022.220)	CIP fields (legal name, DOB, residential address, government-ID number) are collected and verified before the account is transactable (§14); verification failure blocks activation — no default-to-Low.
Beneficial ownership (31 CFR 1010.230 — 25% ownership prong + control prong; FFIEC Appendix 1)	Legal-entity scoring consumes beneficial-ownership and control-person data; opaque/nominee structures floor High or are refused; inability to identify a UBO is a Priority-1 prohibition (§12). High-band / Tier 3 EDD relationships apply the Company's enhanced internal 10% BO threshold (stricter internal standard).
OFAC / targeted sanctions (31 CFR Chapter V; OFAC 50 Percent Rule; blocking & reporting 31 CFR 501.603)	Sanctions/TFS screening is a pre-condition to any rating; a confirmed match, 50%-rule ownership match or sanctioned-jurisdiction nexus is an override (Prohibited/Blocked), never a weighted input; blocking/rejection reports filed within 10 business days and the annual blocked-property report by 30 September.
Non-face-to-face risk (FFIEC electronic-banking guidance)	Digital onboarding and channel-assurance factors carry material weight for new customers to mitigate remote-identity risk (§9).
Ongoing monitoring & SAR (FFIEC SAR/CDD; SAR filing 31 CFR 1022.320; 31 U.S.C. 5318(g))	Expected-vs-actual behaviour feeds the behaviour factor and event-driven re-scoring; deviations route to monitoring and, where warranted, SAR assessment and filing; anti-tipping-off applies (§16).
Currency reporting & structuring (31 CFR 1010.311; 31 U.S.C. 5324)	CTR aggregation at the \$10,000 threshold and structuring around the \$3,000 / \$10,000 thresholds are surfaced through behaviour typologies (§10).
National risk assessments (2026 NMLRA / NTFRA / NPFRA — US Treasury, March 2026)	Threat findings — professional money laundering (incl. Chinese money-laundering networks), money mules, MSB exploitation, check/BEC/elder-fraud proceeds, stablecoin layering, front/shell-company sanctions evasion — are reflected in parameter libraries and floors.
Recordkeeping & reconstruction (FFIEC Appendix P; 31 CFR 1010.430 — 5-year retention)	All inputs, transformations, versions and decisions are retained and reconstructable to the 10-business-day examiner-production standard (§16).
Independent testing & model validation (31 CFR 1022.210 independent review; FFIEC BSA/AML Independent Testing; model-risk expectations)	The Methodology, configuration and outputs are independently validated on a risk-based calendar; independent audit within 12 months of launch and at least annually, reporting to the Board (§17).

Regulatory expectation	Methodology response
Regulatory precedence	Where US law, FinCEN/OFAC requirements, formal supervisory direction or Zenus contractual terms are stricter, they govern and prevail (most-restrictive-standard rule).

3. Authoritative Scoring Framework

3.1 Score scale and the three rating tiers

The model produces a raw composite score on a 1.0000–3.0000 scale mapped to three — and only three — rating tiers. A single override outcome (Prohibited / Blocked / Reject / Exit) sits above the weighted score; it is an action, not a fourth tier. Thresholds are applied to the unrounded raw score.

Raw band	Rating tier	Minimum treatment	Rule
1.0000–1.5000	Low	Standard CDD; simplified only where expressly permitted and no override applies	Apply only where no override or floor forces a higher tier
1.5001–2.1500	Medium	Standard CDD plus targeted monitoring; risk-based EDD triggers	Medium floor rules may force Medium irrespective of the weighted score
2.1501–3.0000	High	Mandatory EDD, senior-compliance approval, enhanced monitoring, reduced limits, ≤12-month review. Confirmed-suspicion-pending-SAR cases are High with documented MLRO sign-off and a 6-month review.	High also applies where any High floor is triggered
Override (not a tier)	Prohibited / Block / Exit	No relationship, or restriction/exit/blocking pending direction	Cannot be downgraded by business or by weighted averaging

3.2 Formula and calculation steps

- Identify segment, lifecycle stage and material related-party roles; load the active model_version_id, weights, thresholds, libraries and override rules;
- Validate mandatory data completeness and screening prerequisites (no scoring before a recorded sanctions/PEP disposition — fail-closed);
- Score parameters using controlled libraries (Low=1, Medium=2, High=3); compute factor scores by weighted average or maximum-risk rule;
- Compute raw composite = $\sum (\text{factor_score} \times \text{factor_weight})$; map to Low / Medium / High;
- Apply prohibitions, High floors and Medium floors in priority order (Section 12); produce outcome, persist the audit record and publish the rating.

3.3 Rounding and precision

Raw scores stored to ≥4 decimals (6 preferred); threshold decisions use the unrounded score. Weights stored as decimals; deployment weight-total tolerance ±0.0001 per set; no intermediate contribution is rounded before summation.

4. Customer Segments and Relationship Hierarchy

Every customer is classified into a segment that selects the factor-weight set, parameter libraries and scoring rules. Material related parties are scored and the highest material related-party risk feeds the customer rating.

Code	Segment	Roles captured	Risk treatment
NP	Natural Person	Customer, joint holder, authorised user, guardian/attorney	NP libraries; employment-type driven. Individual identity via Shufti.
LP	Legal Person / SME	LLC, corporation, partnership, sole-proprietor business, UBOs and control person	Entity profile + ownership/control transparency + industry; each UBO's risk feeds the score; 50% Rule. KYB via SumSub.
MER	Merchant / Platform Seller	Merchant entity, card-acceptance beneficiary	LP scoring plus merchant/MCC and settlement-risk overlays (Rain/Visa).
FI	Financial Institution / Regulated Partner (end-user only)	Permitted regulated NBFIs and banks per Section 6.4	FI six-factor taxonomy (Section 6.3). Shell-bank, nested, domestic-correspondent and third-party-payment-processor relationships prohibited.
EMP	Employee / High-Risk Insider	Staff customer, staff-related account	Relationship risk flag; conflict-of-interest and internal-fraud controls.

5. Factor Weights by Segment and Lifecycle Stage

The raw composite is the weighted sum of factor scores. Weights sum to 100% (± 0.0001) per segment×lifecycle set; “N/A” weight is redistributed within the set.

Factor	NP New	NP Exist	LP/MER New	LP/MER Exist	FI New	FI Exist
Customer / entity profile	25%	20%	25%	20%	15%	15%
Geography / sanctions nexus	25%	20%	20%	15%	20%	20%
Systems & controls (FI only)	N/A	N/A	N/A	N/A	20%	15%
Product / service / corridor	20%	15%	20%	15%	20%	20%
Digital onboarding / channel	20%	15%	15%	10%	10%	10%
Expected activity / behaviour	10%	30%	20%	40%	15%	20%
Total	100%	100%	100%	100%	100%	100%

6. Parameter Libraries and Scoring Rules

Each factor is scored from controlled libraries. Every parameter is scored Low=1, Medium=2, High=3 with a required control/evidence. Libraries are versioned and changed only under Section 17 control.

6.1 Natural Person profile library

Parameter (weight)	Wt	Low = 1	Medium = 2	High = 3
Employment / occupation	15%	Salaried, pensioner, verifiable student	Self-employed, freelancer/gig, small-business owner	Cash-intensive, unverifiable income, high-risk occupation
PEP exposure (max-risk)	15%	No PEP exposure	Domestic PEP, former PEP, or low-materiality associate where risk is manageable	Foreign PEP, IO PEP, or close family/associate of a material PEP (flows High — Section 11.2 definition)
Source of funds quality	15%	Verified salary/pension/benefits	Self-declared with partial evidence	Third-party, unexplained, or inconsistent with profile
Source of wealth complexity	10%	Simple, verifiable	Business/investment wealth	Complex, offshore or opaque; origin in a restricted country

Parameter (weight)	Wt	Low = 1	Medium = 2	High = 3
				requires documented EDD (Section 7.4)
Residency / status coherence	10%	US person/resident, verified address, established tenure	Non-resident in acceptable arrangement; recent tenure	Unclear residence; residence in a restricted/prohibited country; geo conflicts declared address
Adverse intelligence (max-risk)	15%	No material adverse media	Low/moderate, unresolved	Material true adverse media / criminality / prior true match (floors High)
Customer profile / segment	10%	Mass-retail/payroll, verified	Affluent, SME owner, freelancer	HNW/complex, private-banking-like
Mule / synthetic-identity	10%	No indicators	Some first-payer/device signals	Mule-network, synthetic-ID or coached-behaviour indicators (MAL-TA-01 typology)

6.2 Legal Person / SME / Merchant library

Parameter (weight)	Wt	Low = 1	Medium = 2	High = 3
Legal form & structure	15%	Simple US entity, listed/regulated	Standard LLC/SME	Trust/foundation/nominee/bearer or complex layered structure
Ownership & control transparency (max-risk)	20%	UBOs & controllers identified/verified	Multiple layers but resolved	UBO unclear/refused; nominee/front/shell markers (inability to identify UBO → refusal)
Business activity / industry	20%	Low-risk professional/retail/services	General trading, e-commerce, marketplace	Unregistered MSB, unlicensed regulated activity, high-risk cash. Prohibited types (6.4) → reject
Operating history	7.5%	>3 years with evidence	1–3 years or limited	Newly incorporated with high activity or shelf-company markers
Regulatory / licensing status	10%	Licence verified & active	Licence pending/renewing	Unlicensed regulated activity → floor/prohibition
Related-party PEP / sanctions (max-risk)	12.5%	None	Domestic PEP / moderate adverse	Foreign PEP, material adverse, or sanctions nexus on any owner
Business-model transparency	10%	Clear customers/suppliers/flows	Partially explained but plausible	No apparent lawful economic purpose → reject
Corridor concentration	5%	Domestic / low-risk mix	Moderate concentration	Concentration into High corridors (Section 7)

Beneficial-ownership thresholds. Legal-entity scoring applies the statutory 25% ownership prong plus the control prong (31 CFR 1010.230), both applied independently. Consistent with the Program, High-band / Tier 3 EDD relationships apply the Company's enhanced internal beneficial-ownership threshold of 10% identification and verification — a stricter internal standard, not a separate statutory threshold — to give additional depth on the highest-risk relationships where reliance on the statutory minimum would be insufficient.

6.3 Financial Institution / Regulated Partner (end-users only)

Customer-profile factor: Nature of FI activity (25%, max-risk); Legal structure & physical presence (20%; shell bank prohibited); Ownership & control transparency (20%); Regulatory oversight of the FI (20%); Adverse regulatory/financial-crime history (15%). **Systems-and-controls factor:** AML/sanctions program quality (40%); sanctions screening capability (30%); Travel Rule capability for payout partners (30%; data-survival tested). **Evidence:** Wolfsberg DDQ, licence, program and screening attestations.

6.4 Permitted end-users and Prohibited business types

Permitted with Enhanced Due Diligence (end-users only). The following may qualify as GA end-users only, subject to EDD, valid licensing and a robust, evidenced compliance program: regulated institutions (MSBs, EMI, VASPs, PMIs, etc.), commercial banks, broker-dealers, crypto exchanges, and insurance companies. Each is scored under Section 6.3 and floors at High pending EDD clearance. Consistent with the Program, non-profit organisations and charities, and government / embassy / supranational entities, are treated as permitted-with-EDD (enhanced due diligence and ongoing monitoring; an NPO/charity connection is an automatic EDD trigger) rather than as prohibited types — reconciling to the Program’s treatment (e.g., Bangladesh NPO/charity TF exposure; the Pakistan province rule that an NPO/charity connection triggers automatic EDD). Where the Banking Partner (Zenius) contractually prohibits a category, that partner constraint is applied as a separate acceptance gate under the most-restrictive-standard rule until the partner permits.

Prohibited business types (override outcome — reject/exit). The following (Zenius list, reconciled with the Mal CRAM override taxonomy) are not permitted and are declined/exited under Section 12:

- Lawyers (IOLTA accounts), notaries, trustees, accountants
- Offshore banks; domestic correspondent accounts; payable-through accounts; concentration accounts
- Liquor stores, convenience stores, restaurants
- Gaming, casinos, gambling
- Arms and ammunition
- Jewelry and precious metals (DPMS)
- Deposit brokers; brokered deposits
- Cannabis-related businesses (federal-law conflict)
- Bulk shipments of currency; U.S. dollar drafts
- Prepaid access
- Third-party payment processors
- Independent ATM owners/operators
- Non-deposit investment products
- Trust and asset-management services
- Real estate; construction
- Shell banks; unregistered/unlicensed MSBs; anonymous or bearer-like products (Mal CRAM overrides OVR-005/006/007)

7. Geography and Country Risk Methodology

Geography is scored on the geography of funds and country of residence — never nationality or country of birth as a weighted input. Country classifications reconcile OFAC status, the Mal CRAM-01 jurisdiction tiers and the Zenius Restricted Country Codes list under the most-restrictive-standard rule. Two country classes carry an override; permitted corridors are scored Low/Medium/High.

7.1 Prohibited jurisdictions (absolute override — no funds/residence exception)

OFAC comprehensive / region embargo: Iran, Cuba, Syria, North Korea, and the Crimea / Donetsk / Luhansk / Kherson / Zaporizhzhia regions. Mal / Zenus risk-appetite absolute prohibitions (USD-rail reality): Russia, Belarus, Myanmar. Any nexus — residence, source of funds, source of wealth, counterparty corridor, or IP/geolocation — blocks the relationship; funds to or from these jurisdictions are rejected. The only carve-out is the country-of-birth rule in Section 7.4.

7.2 Zenus Restricted Country Codes (last update 04/15/2026)

All countries below are restricted on GA/Zenus rails. They are split into the absolute-prohibited class (7.1) and the non-OFAC restricted-conditional class, which is workable only under the Section 7.4 residency/documentation rule.

Residence in any restricted country, or an active payment corridor to/from it, is blocked regardless of class.

Country	ISO	Class	Country	ISO	Class
Afghanistan	AF	Restricted	Burundi	BI	Restricted
Belarus	BY	Prohibited	Central African Republic	CF	Restricted
Sudan	SD	Restricted	Cuba	CU	Prohibited
Darfur (region)	—	Restricted	Dem. Rep. of the Congo	CD	Restricted
Iran	IR	Prohibited	Iraq	IQ	Restricted
Ivory Coast	CI	Restricted	Kazakhstan	KZ	Restricted
Kosovo	XK	Restricted	Kyrgyzstan	KG	Restricted
Lebanon	LB	Restricted	Libya	LY	Restricted
Mali	ML	Restricted	Nicaragua	NI	Restricted
North Korea	KP	Prohibited	Puerto Rico	PR	Restricted
Russia	RU	Prohibited	Somalia	SO	Restricted
South Sudan	SS	Restricted	Syria	SY	Prohibited
Tajikistan	TJ	Restricted	Turkmenistan	TM	Restricted
Ukraine	UA	Restricted	Uzbekistan	UZ	Restricted
Venezuela	VE	Restricted	Yemen	YE	Restricted
Zimbabwe	ZW	Restricted			

Ratified per Decision Record DR-2026-07-01 (Option A): Puerto Rico (PR) remains Restricted on GA/Zenus rails. PR is a US territory that intersects Mal's Bancrédito / PR IBE perimeter; the conservative Restricted setting is retained under the most-restrictive-standard rule and is not a go-live blocker. Residual administrative action: the US BSA Officer obtains and files written Zenus PR-scope confirmation; PR is re-tiered only if Zenus confirms it is permitted, under change control.

7.3 Customer-specific geography attributes (residency-primary)

Attribute	Weight in geography	Scoring method	Floor / treatment
Country of residence	25%	Lookup country-risk rating	Primary factor. Residence in a restricted/prohibited country → block. High-risk residence floors High unless prohibited.
Nationality (passport)	20%	Highest score across nationalities	Not a weighted input on its own; a restricted/prohibited-country passport triggers screening

Attribute	Weight in geography	Scoring method	Floor / treatment
			escalation and EDD; combined with a residence/SoF/corridor nexus → prohibited (Section 7.4).
Country of birth	10%	Captured where available	Does not alone floor to High or prohibit; a birth-country nexus is a screening/EDD flag only (Section 7.4 carve-out).
Source of funds / source of wealth country	15%	Highest country score across recurring funds and wealth origin	Origin in a non-OFAC restricted country is workable with documentation, EDD and residency tenure (Section 7.4); origin in a prohibited country → block.
Expected transaction corridors	15%	Highest corridor score / exposure-weighted	Active corridor to/from any restricted or prohibited country → reject. High corridor → enhanced monitoring.
Digital geolocation (IP/GPS/device)	15%	Highest risk among signals	Access from a prohibited jurisdiction is an override; VPN/TOR/high-risk mismatch triggers step-up and review.

7.4 Decision rules — residency, documentation and the birth-country carve-out

Rule 1 — Non-OFAC restricted country, resident elsewhere. A customer who resides in a Low- or Medium-risk jurisdiction (not itself restricted) and whose source of wealth and/or source of funds originates from a non-OFAC Zenus-restricted country is not automatically blocked. The case is workable as a High-floor EDD relationship provided: (a) documentary evidence of source of wealth and source of funds is captured and verified; (b) the length/tenure of residency in the current Low/Medium jurisdiction is captured and assessed — longer verified tenure reduces risk, recent relocation warrants deeper EDD; (c) the restricted-country nexus is screened; and (d) senior-compliance approval is recorded. Active payment corridors to/from the restricted country remain blocked.

Rule 2 — Prohibited country. For the absolute-prohibited class (Section 7.1), there is no documentation exception: residence, source of funds, source of wealth, or corridor nexus in a prohibited country blocks the relationship.

Rule 3 — Country-of-birth carve-out. A customer born in a prohibited or restricted country (e.g., born in Russia) who holds a non-prohibited passport and resides in a permitted jurisdiction, with no funds/residence/corridor nexus to the prohibited country, is not prohibited on the basis of birthplace alone. The birthplace is a screening/EDD flag that routes the case to enhanced screening. Holding the prohibited country's own passport (nationality) is a stronger flag and, combined with any residence/SoF/SoW/corridor nexus, results in prohibition.

7.5 Corridor governance and the Program five-band scale

The three mathematical rating tiers of this Methodology (Low / Medium / High) apply to the customer risk rating and are distinct from the corridor risk scale used for corridor go-live governance. For corridor authorization the Company adopts the five-band corridor scale of the Program — Low, Medium, Medium-High, High, Very High — so that every Board corridor trigger has a defined home. No corridor goes live without a completed Corridor Addendum signed by the CO; High and Very High Risk corridors additionally require Board approval before go-live, and Medium-High Risk corridors require CO sign-off with Board notification within 30 days.

Program corridor band	Board go-live governance	CRAM corridor treatment
Very High	Board approval before go-live (non-delegable).	Corridor scored High; Tier 3 default; province/sub-region sub-risk applied where relevant.
High	Board approval before go-live (non-delegable).	Corridor scored High; minimum Tier 2, Tier 3 for elevated factors.
Medium-High	CO sign-off plus Board notification within 30 days.	Treated as a High corridor for monitoring, limits and EDD gating; minimum Tier 2, Tier 3 where elevated factors.
Medium	CO sign-off; Corridor Addendum on file.	Corridor scored Medium; standard CDD plus targeted monitoring.
Low	Standard; Corridor Addendum on file.	Corridor scored Low.

Legacy note. The prior three-band corridor presentation (Low/Medium/High) is retained for scoring, but corridor go-live decisions are governed by the five-band Program scale above; a Medium-High corridor is no longer collapsed into Medium or High for governance purposes.

7.6 Active corridors (Program alignment)

The Program is built around five named corridors. None of these appears on the Zenus Prohibited or Restricted Country Codes list (Sections 7.1–7.2); they are permitted, actively governed corridors carried at the Program’s internal risk classification and reconciled here under the most-restrictive-standard rule.

Corridor	Program band	Primary internal risk basis	CRAM corridor treatment
Pakistan	Very High	TF risk; hawala/hundi prevalence; KPK/FATA/Balochistan province risk; weak institutional controls.	High corridor; Tier 3; Pakistan province sub-risk (7.6.1).
Bangladesh	High	Trade-based ML; NPO/charity TF exposure; weak AML enforcement; remittance vulnerability.	High corridor; min Tier 2, Tier 3 for elevated factors; NPO/charity = auto EDD.
Egypt	High	Currency-control evasion; informal economy; limited AML enforcement; regional sanctions proximity.	High corridor; min Tier 2, Tier 3 for elevated factors.
Turkey (Türkiye)	Medium-High	Geographic position; gold/CVC trading risk; historical ML typologies; residual post-FATF-removal risk.	Medium-High corridor → CO sign-off + Board notification; Tier 2 default, Tier 3 where elevated.
UAE	Medium-High	Trade-finance ML; real-estate risk; high-value cash economy; proximity to sanctioned jurisdictions.	Medium-High corridor → CO sign-off + Board notification; Tier 2 default, Tier 3 where elevated.

7.6.1 Pakistan province-level sub-risk

Within the Pakistan corridor the following province/region sub-risk applies, mirroring the Program’s internal assessment.

Province / Region	Sub-risk	EDD treatment
Islamabad Capital Territory	Medium-High	Standard Tier 2 plus volume monitoring; geographic review on threshold breach.
Punjab (Lahore, Faisalabad)	High	Tier 2+; transaction thresholds 30% lower than standard; enhanced SoF documentation above corridor threshold.
Sindh (Karachi)	High	Tier 3 default; senior/compliance approval required; monthly CO review of all active accounts.

Province / Region	Sub-risk	EDD treatment
Azad Kashmir / Gilgit-Baltistan	High	Tier 3 default; cross-border flow monitoring; NPO/charity connection = automatic EDD trigger.
KPK / FATA / PATA	Very High	Tier 3 MANDATORY; enhanced TF screening; CO pre-approval per individual onboarding; NPO connection = automatic EDD.
Balochistan	Very High	Tier 3 MANDATORY; prior CO approval per onboarding; monthly CO review of all active accounts in this province.

8. Product and Service Risk Methodology

Product / service	Inherent driver	Base score
Domestic USD account / VRN receipt	Standard deposit/receipt	Low
Inbound ACH / payroll	Low-value, traceable	Low
Card spend (Rain/Visa)	Merchant/settlement risk; scheme rules	Medium
Outbound cross-border payout (bank — Thunes)	Cross-border, corridor-dependent	Medium–High
Outbound cross-border payout (stablecoin-settled — SwiftX)	CVC settlement-layer + corridor risk	High
SWIFT fallback wire	High-value, correspondent-chain	High
USDC treasury interaction (program-level)	CVC exposure; wallet risk	High (program control)

A customer's product mix is scored on its highest-risk enabled product and intensity of use. Stablecoin-settled corridors carry a settlement-layer overlay. New high-risk products/corridors are gated (SOP 30). Minimum product score for any enabled outbound cross-border corridor is Medium, rising to High for High corridors or stablecoin-settled legs.

8.1 VRN lifecycle and cost governance

VRN issuance is tracked because each VRN carries a recurring cost (\$/month per VRN) and affects inbound payment success paths. A cancellation process is maintained: a VRN cancellation spreadsheet is submitted, and cancellation is not immediate (portal steps plus a JP Morgan step). Issuance and cancellation status are reconciled monthly by Ops; stale/unused VRNs are cancellation candidates.

9. Digital Onboarding and Channel Assurance

9.1 Identity-verification vendor map

Individual (NP) KYC is performed by Shufti; KYB (LP/MER/FI entity verification) and KYB transaction monitoring are performed by SumSub; decisioning is via Oscilar. The identity-verification strength parameter requires document authentication plus liveness/selfie match with device/geo coherence, supplemented by non-documentary corroboration and per-script transliteration handling.

Parameter	Low = 1	Medium = 2	High = 3
Identity verification strength	Document auth + liveness + selfie match passed (Shufti for NP; SumSub for KYB), device/geo coherent	Passed with minor manual remediation	Weak/failed verification; biographical-manipulation or document-swap indicators
Device / network coherence	Consistent device, low-risk IP/geo	Some anomalies	High-risk IP, VPN/proxy obfuscation, device-farm indicators

Parameter	Low = 1	Medium = 2	High = 3
Contact-point assurance	Verified phone/email possession	Partial	Unverifiable or shared contact points
Onboarding behaviour	Normal flow	Some velocity/pattern anomalies	Bot/scripted or coordinated-signup indicators

9.2 Existing-customer channel and US-citizen-abroad handling

- Device change combined with beneficiary change and velocity (account-takeover signature) raises the channel factor and triggers step-up authentication; sustained access from prohibited/high-risk geolocations is an override input.
- US-citizen-abroad (W-9 / SSN): an SSN-validation API error blocking US citizens onboarding from abroad is a known integration data-quality issue, escalated to the integration team with API evidence and tracked as a data-quality exception. Affected cases are held (not defaulted to Low) until the SSN/TIN data point is validated or an approved alternative CIP path is documented; CIP is never relaxed to clear the error.

10. Expected Activity, Behaviour and Typology Anchoring

An expected-activity profile (volumes, corridors, counterparty types, funding sources) is recorded at onboarding. The behaviour factor scores coherence at onboarding and, for existing customers, deviation of observed activity from that baseline.

Parameter	Low = 1	Medium = 2	High = 3
Expected-vs-actual coherence	Consistent with profile	Some deviation, explained	Material unexplained deviation
Velocity / pass-through	Normal dwell and turnover	Elevated turnover	Rapid pass-through, low-dwell, in-out symmetry (layering)
Counterparty coherence	Consistent, explainable	Some new/unexplained	Counterparty incoherence, mule clustering, structuring
Funding-source risk	Verified, low-risk	Mixed/partly verified	Third-party/CVC-sourced/unexplained; check-fraud/BEC/scam-proceeds indicators

10.1 Enterprise typology register (MAL-TA-01)

Behaviour parameters and monitoring scenarios operationalise the Financial Crime Typology Assessment Report. Each typology is a High-priority threat unless noted; indicators are illustrative and applied with judgment.

Typology	Key red flags	Linked scenarios
Abuse of bank accounts	Rapid movement; high inflows then immediate outward transfers; activity inconsistent with profile	OS-TM-003/004/029; 005-007
Fraud-proceeds laundering (BEC, pig-butcher, investment scams)	Victim complaints; funds from unrelated individuals; rapid conversion/withdrawal	OS-TM-012-015/025; 016/017
Money-mule networks	Multiple unrelated credits, funds quickly out; new customers with sudden high activity; common IP/device/address	OS-TM-016/017/027/036/039
Third-party ML (incl. professional networks)	Payments unrelated to business; nominee shareholders/directors; unclear economic rationale	OS-TM-003/004; 022/023

Typology	Key red flags	Linked scenarios
Abuse of legal persons (shell/front)	Complex/offshore ownership; nominee UBOs; frequent director/shareholder changes; weak substance	OS-TM-001/002; 022/023
Trade-based ML (TBML)	Over/under-invoicing; mismatched goods; unusual routes; circular trade	OS-TM-008/009/030–032/035
Sanctions / PF / TFS evasion	Dual-use goods; fake shipping/customs docs; Iran/DPRK nexus; shell companies	OS-TM-010/011/028/033/034
High-risk jurisdiction exposure	Payments to/from high-risk countries; routing through multiple jurisdictions; inconsistent origin/destination	OS-TM-008/009/030–032/035
PEP / foreign corruption	PEP match; unexplained wealth; state-linked counterparties; govt-contractor payments; adverse media	OS-TM-022/023
Digital-channel abuse	Multiple logins/devices; account-takeover signatures; coordinated signups	OS-TM-018–020/026/037
Virtual-asset / stablecoin layering	Mixer/tumbler routing; sanctioned-wallet adjacency; rapid on/off-ramp	Program CVC controls
Structuring	Transactions just under the \$3,000 / \$10,000 thresholds; patterned deposits	Structuring scenarios

11. Screening, Sanctions, PEP and Adverse Intelligence

Screening is a pre-condition to any rating outcome, not a weighted input: no customer is scored or activated before a recorded sanctions/PEP disposition (fail-closed). Confirmed matches are frozen without delay and reported.

11.1 Residency-primary and nationality/birth handling

Country risk applies residency as the primary factor and scores on the geography of funds. Nationality and country of birth are screening/EDD inputs, not weighted scoring inputs (non-discrimination / UDAAP). A restricted/prohibited-country nationality or birthplace triggers screening escalation and EDD per Section 7.4; funds to/from restricted or prohibited jurisdictions may be rejected.

11.2 PEP definition and treatment

PEP definition (adopted from the Mal CRAM). A politically exposed person is any individual entrusted with a prominent public function — including foreign PEPs, domestic PEPs, and persons entrusted with a prominent function by an international organisation (IO PEP) — together with their immediate family members and known close associates. Former PEPs are risk-assessed on residual influence. Treatment: foreign PEPs, IO PEPs, and close family/associates of a material PEP are usually High and floor to High, with corroborated source of wealth/funds and senior approval; domestic and former PEPs are Medium or High based on role, materiality and controls. Screening is dual-method (database + self-certification), pre-onboarding and on ongoing refresh.

Zenus PEP definition. The current Zenus PEP definition is held on file and refreshed when partner policy changes; where Mal's and Zenus's definitions differ, the stricter definition governs.

11.3 Sanctions, blocking and adverse intelligence

- Sanctions / TFS: a confirmed OFAC (SDN/consolidated) match, a 50% Rule ownership match, or a comprehensively sanctioned-jurisdiction nexus is an override — Prohibited/Blocked. SDN deltas live ≤24h (other lists ≤48h) with automatic full-base batch re-screening; approved fuzzy/transliteration matching, independently validated with periodic seeded-name testing.

- Blocking / rejection reporting: filed with OFAC within 10 business days (31 CFR 501.603); Annual Report of Blocked Property filed by 30 September; blocked property is never returned.
- Adverse intelligence: credibility- and materiality-assessed; material true adverse media floors High or reject.
- Provenance: every screening disposition, list version and rationale is recorded in the Decision Provenance Log and is reproducible point-in-time.

12. Overrides, Risk Floors and Prohibitions

Overrides and floors are applied after the weighted score, in priority order, and cannot be diluted by weighted averaging or downgraded by business. There is no Critical tier; hard cases resolve either to the Prohibited override or to High with MLRO sign-off.

Priority	Condition	Effect
1 — Prohibition	OFAC/SDN match; 50% Rule; prohibited or restricted-country nexus per Sections 7.1–7.4 (residence/SoF/SoW/corridor); shell bank; domestic correspondent; third-party payment processor; any Prohibited business type (6.4); unregistered money transmission; inability to identify UBO; no lawful economic purpose; transacting from a prohibited jurisdiction	Prohibited / Reject / Block / Exit
2 — Confirmed suspicion / TF (→ High + MLRO)	Confirmed suspicion pending SAR; sanctioned-wallet/mixer exposure; confirmed TF nexus	High with documented MLRO sign-off, 6-month review, tightest limits or exit; SAR fired
3 — High floor	Confirmed foreign/senior/IO PEP or close associate of material PEP; material adverse media; High-corridor concentration; opaque/nominee structure; stablecoin high-risk corridor; non-OFAC restricted-country SoW/SoF under Section 7.4; permitted FI end-user pending EDD	High → EDD, senior-compliance approval, reduced limits, ≤12-month review
4 — Medium floor	Non-face-to-face with residual verification risk; new high-risk product; moderate adverse; new entity with high activity	Medium → targeted monitoring and risk-based EDD

Manual overrides require documented rationale, evidence and an expiry date; downgrades require Compliance approval and can never override a Priority-1 or Priority-2 condition. Override volume and direction are a standing KRI (Section 18).

13. Due Diligence, Approval, Monitoring and Review Outcomes

Rating	CDD/EDD	Approval	Monitoring & limits	Review
Low	Standard CDD	System	Baseline; standard limits	36 months
Medium	Standard CDD + targeted rules	System (Compliance review on floor)	Targeted	24 months
High	Mandatory EDD; SoW/SoF	Senior-compliance; MLRO for confirmed-suspicion	Enhanced; reduced limits	12 months (6 if MLRO-escalated)
Prohibited	N/A	Reject / block / exit	No relationship	N/A

13.1 EDD evidence matrix

EDD trigger	Minimum additional evidence
Confirmed PEP / High band	Corroborated source of wealth; enhanced ID; senior-approval record; enhanced-monitoring flag

EDD trigger	Minimum additional evidence
Non-OFAC restricted-country SoW/SoF (Section 7.4)	Documentary SoW and SoF evidence; proof of current residence and residency tenure (permit dates, address history); restricted-country nexus screening; senior-compliance approval
Opaque/complex ownership (SME)	Full ownership chart to natural persons; nominee/UBO resolution; registry evidence
High-corridor concentration	Corridor rationale; beneficiary coherence (name-ID-IBAN/wallet match); purpose-of-payment evidence
Material adverse intelligence	Adverse-media assessment memo; disposition rationale; ongoing-monitoring plan
Permitted FI end-user (6.4)	Wolfsberg DDQ; licence; AML/sanctions program + screening + Travel-Rule evidence

14. Data Model and Data Quality

14.1 Core data domains

- Customer & related-party — identity, segment, employment/entity, beneficial ownership, PEP/screening status;
- Geography — declared address, device/IP geolocation, residence country and tenure, nationality, birth country, corridor and counterparty jurisdictions;
- Product & channel — enabled products/corridors, onboarding channel, device/session;
- Behaviour — expected-activity profile, observed transactions, counterparties, funding sources;
- Scoring & governance — factor/parameter scores, model_version_id, library versions, overrides, reason codes, audit record.

14.2 Minimum field catalogue (scoring-critical)

Domain	Minimum fields	Source system
Identity (CIP)	Full legal name, DOB, residential address (no PO box), government-ID number, verification result — before the account is transactable	GA app / Shufti (NP)
Beneficial ownership (SME)	UBO name/DOB/address/ID, ownership %, control person, certification	KYB flow / SumSub
Screening	Sanctions/PEP/adverse disposition, list version, match score	Oscilar
Geography	Residence country + tenure, nationality, birth country, SoF/SoW country, corridor, counterparty jurisdiction, device/IP geo	GA app / Oscilar
Behaviour / KYB monitoring	Expected profile, observed volume/velocity/counterparties, funding source	SaaScada / Oscilar / SumSub (KYB TM)
Scoring	Factor & parameter scores, weights, model_version_id, overrides, reason codes	CRAM engine

14.3 Baseline KYC-before-transacting and RFI reduction

- Baseline artefacts before transacting: government ID/passport, proof of address, and proof of employment / source of funds as applicable. Missing artefacts block activation (no default-to-Low).
- RFI reduction: supporting documents (invoice / contract / agreement) are embedded in the transaction payload and the relationship and rationale between parties are clarified up front.
- Data quality: scoring-critical fields must be complete, valid and coherent before a rating is finalised; failure blocks approval or forces conservative treatment. Lineage is maintained for point-in-time reproducibility.

15. Calculation Sequence, Workflow and SLAs

Calculation sequence: segment/lifecycle identification → load model version & config → validate data & screening prerequisites → score parameters → compute factor scores → compute raw composite → map to tier → apply overrides/floors (priority order) → produce outcome (rating, CDD/EDD, approval route, monitoring, next review) → persist audit record → publish rating.

15.1 Workflow states

State	Meaning
Draft	Assessment initiated; data being gathered
Pending data / screening	Blocked on mandatory data or a screening disposition (fail-closed)
Scored	Raw score and tier computed
Overrides applied	Floors/prohibitions resolved in priority order
Approved / Declined	Outcome decided at the required authority
Published	Rating published to source and downstream systems
Under review / re-score	Event-driven or periodic reassessment in progress

15.2 Event triggers and SLA matrix

Trigger	Action	SLA
Onboarding	Full assessment before activation (pre-funding gate); baseline KYC present	At onboarding
Watchlist / list update	Delta re-screen + re-score affected	SDN ≤24h / other ≤48h; re-score on hit
RFI raised / transaction held	Respond to the RFI; request an extension if the customer is unreachable	72-hour response window
Material profile / ownership / corridor / product change	Event-driven re-score	Real-time / next business day
Alert triage	Triage into P1/P2/P3 with response SLAs	P1 ≤4h · P2 ≤24h · P3 ≤48h
Investigation / SAR event	Re-score; override; escalate per §15.3	Within case handling
Periodic review	Full refresh per tier cadence	36 / 24 / 12 (6 if MLRO-escalated) months

15.3 SAR filing, escalation and communications discipline

Interim dual filing. SAR filing follows the Program's two-path model. Either (Path A) the Company is the confirmed filing institution and files the SAR directly with FinCEN within 30 days at the \$2,000 MSB threshold (31 CFR 1022.320), or (Path B) the Banking Partner is the filing institution and the Company prepares and transmits a complete escalation package within ~20 days to support the Partner's 30-day deadline. The definitive filing-institution allocation is fixed by the Governance, Regulatory Perimeter and Compliance Positioning Memorandum. Interim measure: until that allocation is confirmed with Zenus and counsel, the Company escalates suspicious activity both internally and to Zenus so that no filing obligation is missed; this interim dual escalation is superseded once the Memorandum confirms the applicable path, and this section is updated under change control.

Escalation and reporting coordination uses the agreed supervisor contacts: Andres Rey Collazo, Miguel Otero, plus the supervisor on call. Timeliness is confirmed per scenario; some cases require rapid reporting. Communications discipline: avoid excessive follow-up emails that clog queues; escalate to senior contacts only after a reasonable wait (guidance: if no response in ~2 business days, escalate).

16. Record Keeping, Audit Trail and Explainability

- Every assessment persists an immutable record: inputs, factor/parameter scores, weights, model_version_id, library versions, overrides, reason codes, outcome, approver, timestamps, and the authorized-user access register.
- Reason codes and evidence references are generated for all non-Low factors, overrides, data-quality exceptions and decisions.
- SAR confidentiality: no person is informed a SAR has been, will be, or is being considered for filing; SAR records are access-restricted and retained five years.
- Records retained per Mal-POL-REC-01 (5-year default; 10-year sanctions-linked), tamper-evident and retrievable to the 10-business-day examiner-production standard; point-in-time reconstruction is supported.

17. Model Governance, Validation and Change Control

- Gate 1 — Methodology freeze; Gate 2 — Build validation (UAT/SIT against the test pack, including the assertion that no output can ever be Critical/Moderate-High); Gate 3 — Independent pre-production validation; Gate 4 — Launch + 90-day live-data re-score before production certification.
- Calibration: thresholds risk-coherent (no clustering just below High); maximum-risk parameters verified non-dilutable; override/floor logic tested — seeded prohibited-country, restricted-country-SoW, prohibited-business, PEP and confirmed-suspicion cases must reach the correct outcome.
- Change control (SOP 29): hypothesis → test → Model Risk Committee approval → versioned deployment → post-deployment monitoring; every change increments the model_version_id; vendor-model changes (Oscilar/Shufti/SumSub) are validated by Mal, not accepted on attestation.
- Independent audit: an independent test of the BSA/AML and sanctions programme by parties independent of the functions tested (excluding the Compliance Officer), within 12 months of launch and at least annually, reporting to the Board; scope covers the risk assessment, CIP/KYC/EDD file testing, monitoring/alert quality, SAR decisioning, OFAC configuration and blocked-property handling, Travel Rule, recordkeeping, training and partner oversight.

18. MI, KRIs and Ongoing Monitoring

This MI feeds the Board-mandated reporting artifacts under the Program — the quarterly Board compliance dashboard (Program Annex 12) and the annual Program Effectiveness Report. Reported to the Model Risk Committee and, in summary, to the Board quarterly: portfolio tier distribution and migration; override volume and direction, and High-band MLRO-escalated admissions; floor-trigger frequency (PEP, adverse, corridor, ownership, restricted-country SoW, stablecoin); data-quality exceptions and no-default-to-Low blocks (including the US-citizen-abroad SSN/W-9 backlog); RFI response-window adherence; trigger-driven re-score volumes and latency; periodic reviews due/overdue; model drift; validation-calendar adherence; and screening/list-freshness.

19. Final Methodology Control Statement

This Methodology is Mal's authoritative Customer Risk Assessment Methodology for the United States perimeter of the Global Accounts program. It produces exactly three risk tiers (Low / Medium / High) with a Prohibited override above the weighted score; it applies the Zenus Restricted Country Codes list under a residency-primary model with a documented exception for non-OFAC source-of-wealth/funds origin and a country-of-birth carve-out; it adopts the Mal CRAM PEP definition, prohibited-business set and country-risk pillars; and it anchors behaviour to the Financial Crime Typology Assessment Report. It is drafted to be testable and examinable, with reproducible scoring, hard stops above the weighted score, reason codes and point-in-time reconstruction. It is production-build ready at model version CRAM-US-2026-07-FREEZE-03 and becomes production-certified only on completion of the Section 17 gates. This document is regulatory information support, not legal advice; counsel review is required before adoption, and the Puerto Rico restriction (Section 7.2) must be confirmed with Zenus and Legal before go-live.

20. Appendices

Appendix 1 — Validation test pack (key assertions)

- Precision/rounding; tier-boundary mapping (1.5000/1.5001; 2.1500/2.1501); assert no output is ever Critical/Moderate-High.
- Maximum-risk parameters drive the factor without dilution; override/floor logic cannot be averaged away.
- Seeded cases reach the correct outcome: prohibited-country nexus → Prohibited; non-OFAC restricted-country SoW with documentation + Low/Medium residence → High (not blocked); born-in-Russia + non-Russian passport + permitted residence + no nexus → not prohibited (flag only); prohibited-business → Prohibited; foreign PEP → High.
- Fail-closed screening; delta re-screen re-scores on hit; reproducibility from stored inputs and versions.

Appendix 2 — Implementation checklist

#	Item	Owner	Evidence
1	Board approval of Customer Risk Rating Policy fronting this Methodology	Board / MLRO	Resolution
2	Config locked to CRAM-US-2026-07-FREEZE-03 (three-tier)	Engineering	Version-locked config
3	Zenus lists loaded — restricted countries (2 classes), prohibited businesses, permitted end-users, PEP definition	Engineering / US BSA Officer	Config + test
4	Section 7.4 residency/SoW logic + tenure capture implemented	Engineering	Rule test
5	Puerto Rico set to Restricted per DR-2026-07-01; written Zenus confirmation to be filed	US BSA Officer	DR-2026-07-01 + Zenus confirmation
6	Vendor map wired: Shufti (NP KYC), SumSub (KYB + KYB TM), Oscilar (decisioning)	Vendor Governance	Vendor validation
7	Interim dual SAR filing (Mal + Zenus) operational; escalation contacts loaded	US BSA Officer	Procedure
8	RFI 72h window, P1/P2/P3 SLAs, baseline-KYC gate operational	FinCrime Ops	SLA config
9	SSN/W-9 US-citizen-abroad fix tracked with integration team	US BSA Officer	Issue log
10	Independent validation + launch+90 re-score scheduled	MLRO	Plan

— End of document —